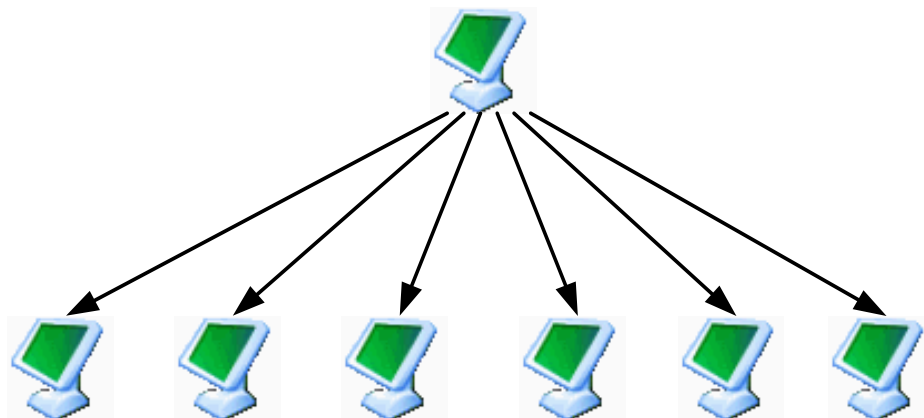


บทที่ 5

การสแกนเพื่อตรวจสอบ

5.1 Network Ping Sweeps



รูปที่ 5-1 แสดงการทำงานของ *ping sweep*

หนึ่งในเทคนิคพื้นฐานที่นิยมกระทำกันก็คือ การ ping ไปยังเครื่องเป้าหมายจำนวนมากพร้อมๆ กัน ในลักษณะคล้ายกับการกวาดหรือกราดยิง ซึ่งเราเรียกว่าการทำ ping sweep เพื่อตรวจสอบว่าเครื่องปลายทางใดบ้างที่ยังเปิดทำงานอยู่ โดยปกติ ถ้าคุณใช้คำสั่ง ping ธรรมดา, ping จะมีการส่ง แพ็กเก็ต ICMP ECHO (Type 8) ออกไปยังเครื่องปลายทางและรอคอย ICMP ECHO_REPLY (Type 0) ที่ถูกส่งกลับมา ถึงแม้ ping จะมีประโยชน์สำหรับการทดสอบว่าเครื่องปลายทางเปิดอยู่หรือไม่ก็ตาม แต่มันจะเหมาะสำหรับเครื่องที่อยู่บนเน็ตเวิร์คขนาดเล็กถึงขนาดกลางเท่านั้น มันจะไม่มีประสิทธิภาพเพียงพอที่จะนำมาใช้ตรวจสอบเครื่องที่อยู่บนเน็ตเวิร์คขนาดใหญ่ได้ การตรวจสอบเครื่องที่อยู่ในเน็ตเวิร์คที่ใช้แอดเดรสในคลาส A อาจกินเวลานานหลายชั่วโมงกว่าจะทราบผล เทคนิคในการ ping sweep มีหลายเทคนิคแตกต่างกันไป เช่น ปกติแล้วการ ping จะรอคอยการตอบสนองจากเครื่องทีละเครื่อง ก่อนจะไปเปลี่ยนไปทดสอบเครื่องอื่นๆ ถัดไป มันจะใช้การส่ง แพ็กเก็ต ICMP ออกไปพร้อมๆ กันแบบขนานไปยังเครื่องปลายทางหลายๆ เครื่อง ในลักษณะคล้าย “Round Robin” (คือส่งแพ็กเก็ต ICMP ไปที่เครื่อง 1,2,3,... ถึงเครื่องสุดท้าย แล้ววนกลับมาส่งแพ็กเก็ตไปที่เครื่อง 1,2,3 ใหม่ไปเรื่อยๆ แล้ววนกลับมาอีก โดยไม่ต้องหยุดรอจากตอบสนองจากเครื่องแรก) ดังนั้น จะทำงานได้รวดเร็วกว่าคำสั่ง ping ธรรมดามาก แต่

อาจทำให้เกิดทราฟฟิกจำนวนมากที่เกิดขึ้นอาจเข้าไปรบกวนแบนด์วิธของ WAN Link ความเร็วอย่างต่ำ เช่น 128K ISDN หรือ เฟรมรีเลย์ (Frame relay)

แต่ในบางครั้งจะอย่างไรถ้าที่เน็ตเวิร์กเป้าหมายได้มีการบล็อกห้ามแพ็กเก็ต ICMP ไว้ไม่ให้เข้าถึงเน็ตเวิร์กภายในได้

ถ้าแพ็กเก็ต ICMP ถูกบล็อกเอาไว้ เรามีเทคนิคและเครื่องมืออื่นที่ใช้ตรวจสอบได้ว่าเครื่องปลายทางใดบ้างที่เข้าถึงได้และเปิดทำงานอยู่ แต่อย่างไรก็ตาม มันอาจไม่ถูกต้องและรวดเร็วเท่ากับตรวจสอบด้วย ping sweep

เทคนิคที่ว่ามันก็คือ การสแกนพอร์ต นั่นเอง ซึ่งเป็นเทคนิคแรกที่ใช้ถ้าใช้ปลายทางบล็อกแพ็กเก็ต ICMP ไว้ โดยการสแกนพอร์ตทั่วๆ ไปบนแต่ละเครื่องเราจะสามารถคาดการณ์ได้ว่าเครื่องไหนเปิดอยู่บ้าง เทคนิคนี้ค่อนข้างกินเวลาและอาจไม่สามารถสรุปแน่ชัดได้ TCP Ping Scan ด้วย TCP Ping scan ไปที่พอร์ตที่ต้องการส่วนมากจะเป็นพอร์ต 80 เนื่องจากเป็นพอร์ตมาตรฐานที่เร้าเตอร์หรือไฟร์วอลล์ของไชต์ส่วนใหญ่จะเปิดไว้ให้ผ่านเข้าไปได้ยังเว็บเซิร์ฟเวอร์ที่มักตั้งอยู่ในส่วนที่เรียกว่า Demilitarized zone (DMZ) หรือยิ่งไปกว่านั้น อาจทะลุผ่านเข้าไปในอินทราเน็ตภายในด้วย โดยจะทำงานดังนี้คือสร้างแพ็กเก็ตของโปรโตคอล TCP ซึ่งได้เซตแฟล็ก ACK (Acknowledge) ไว้เป็น 1 ด้วย (ต่อไปเราจะเรียกแพ็กเก็ตลักษณะนี้สั้นๆว่า แพ็กเก็ต TCP ACK) แล้วส่งแพ็กเก็ตเหล่านี้ไปยังเน็ตเวิร์กเป้าหมายปลายทางหรือไม่ ถ้ามีก็แสดงว่าเครื่องปลายทางสามารถติดต่อได้และเปิดทำงานอยู่ แพ็กเก็ต TCP ACK นี้มักวิ่งทะลุผ่านไฟร์วอลล์ที่ไม่ค่อยฉลาดนักหรือคอนฟิกไว้ไม่ดีพอให้เข้าไปได้

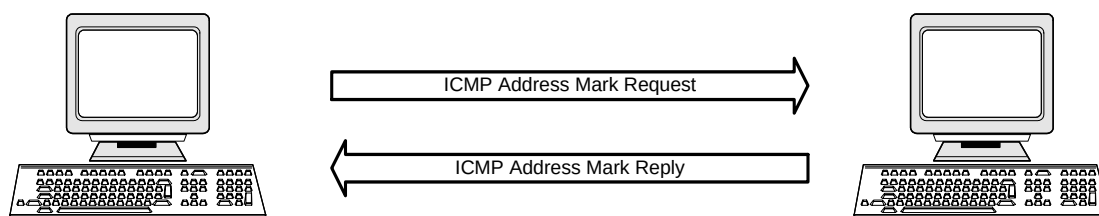
อย่างที่ไดเห็นไปแล้วว่าเทคนิคนี้ค่อนข้างใช้ได้ผลถึงแม้ไชต์ปลายทางจะบล็อกแพ็กเก็ต ICMP ไว้ ซึ่งถ้า พอร์ต 80 ใช้ไม่ได้อาจใช้เป็นพอร์ตมาตรฐานที่มักพบบ่อย อย่างเช่น พอร์ตของเซอร์วิส SMTP (หมายเลข 25), POP (110), AUTH (113), IMAP (143) หรือพอร์ตอื่นๆ ที่เป็นไปได้

ถ้าพอร์ตที่เครื่องปลายทางได้เปิดไว้แพ็กเก็ตของโปรโตคอล TCP ที่มีการเซตแฟล็ก SYN(S bit) ไว้และแพ็กเก็ต TCP ที่มีการเซตแฟล็ก ACK ไว้จะถูกส่งกลับมา

นอกจากนี้ยังมีเทคนิคอื่นในการที่จะตรวจสอบว่าเครื่องปลายทางยังเปิดทำงานอยู่หรือไม่ด้วยการส่งแพ็กเก็ต ICMP ECHO ออกไป พร้อมทั้งแพ็กเก็ตของโปรโตคอล ICMP ใน Type อื่นๆด้วย ได้แก่ ICMP Type TIME STAMP REQUEST และ ICMP INFO request เพื่อที่ว่า ถึงแม้แพ็กเก็ต ICMP ใน Type ECHO ถูกสกัดกั้นไว้ที่เร้าเตอร์ตัวที่เชื่อมต่อออกอินเทอร์เน็ตหรือที่ไฟร์วอลล์ก็ตาม แต่โอกาสที่แพ็กเก็ต ICMP ใน Type อื่นๆจะวิ่งทะลุผ่านเข้าไปเพื่อตรวจสอบได้ก็ยังมีอยู่ หรืออาจจะส่งไปด้วยแพ็กเก็ตปลอม (spoofed packet) เพื่อป้องกันการตรวจสอบย้อนกลับไปว่าแพ็กเก็ตถูกส่งมาจากที่ไหน

กล่าวโดยสรุป ขั้นตอนนี้จะทำให้เราสามารถตรวจสอบได้อย่างแท้จริงว่าเครื่องปลายทางใดบ้างที่เราสามารถติดต่อได้โดยตรงผ่านอินเทอร์เน็ต ด้วยการส่งแพ็กเก็ต ICMP ใน TYPE ต่างๆ หรือใช้เทคนิคของการสแกนพอร์ตเข้าไปตรวจสอบ จากลิสต์รายการหมายเลข IP Address ที่อยู่ในคลาส C จำนวนกว่า 200 หมายเลข เราสามารถตรวจสอบได้ว่าแท้จริงแล้วมีเครื่องไหนบ้างที่อยู่ในขอบข่ายของการเป็นเครื่องเป้าหมายได้ เพื่อช่วยลดไฟก๊สขอบเขตของการตรวจสอบให้แคบลงและประหยัดเวลามากขึ้น

5.2 ICMP Queries



รูปที่ 5-2 แสดงการทำงานของ ICMP QUERY

คือการส่งแพ็กเก็ตของโปรโตคอล ICMP ไปสอบถาม ตัวอย่างเช่น สอบถามเวลาของเครื่องปลายทาง (เพื่อดูว่าเครื่องนั้นอยู่ในโซนเวลา (time zone) แอปใด) ด้วยการส่งแพ็กเก็ต ICMP type TIMESTAMP, สอบถามค่าของ Subnet Mask ของเครื่องปลายทางด้วยการส่งแพ็กเก็ต ICMP type ADDRESS MASK REQUEST Subnet Mask เป็นค่าที่สำคัญพอสมควรเพราะมันจะทำให้คุณทราบหมายเลข Subnet Address ของเครื่องเน็ตเวิร์กเป้าหมาย การทราบค่าของ Subnet Address จะช่วยให้เราสามารถโฟกัสไปที่เน็ตเวิร์กที่ต้องการได้และหลีกเลี่ยงการส่งข้อมูลโดยระบุแอดเดรสปลายทางเป็น Broadcast Address

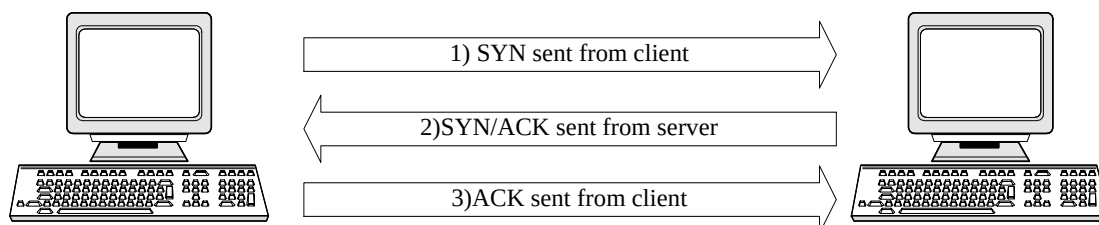
5.3 Port Scanning

การสแกนพอร์ตหรือ Port Scanning เป็นกระบวนการในการคอนเน็กเข้าไปที่ TCP Port หรือ UDP Port ของเครื่องปลายทางเพื่อค้นหาว่ามีเซิร์ฟเวอร์อะไรบ้างที่ทำงานอยู่หรืออยู่ในสถานะ LISTENING

การค้นหาพอร์ตที่เปิดอยู่เป็นเรื่องสำคัญทีเดียวในการตรวจสอบประเภทของระบบปฏิบัติการและแอปพลิเคชันที่ใช้งานอยู่ในระบบ เพราะ ระบบปฏิบัติการหรือเซิร์ฟเวอร์ที่รันอยู่อาจมีข้อบกพร่องบางอย่างที่อนุญาตให้ผู้ใช้ที่ไม่ได้ผ่านการตรวจสอบเข้าไปในระบบได้ หรือมีข้อบกพร่องเกี่ยวกับระบบการรักษาความปลอดภัยที่เป็นที่รู้กันดี โดยเฉพาะเซิร์ฟเวอร์ชั้นที่ยังไม่สมบูรณ์ เครื่องมือและเทคนิคในการสแกนพอร์ตได้รับการพัฒนาอย่างต่อเนื่องมาหลายปี เทคนิคการสแกนพอร์ตที่เรากล่าวไปข้างต้นนั้น เป็นเพียงการสแกนพอร์ตเพื่อรู้ว่าเครื่องปลายทางเปิดอยู่และติดต่อผ่านทางอินเทอร์เน็ตหรือเครือข่ายได้หรือไม่ เท่านั้น แต่สำหรับเทคนิคการสแกนพอร์ตที่จะกล่าวถึงถัดนี้ไป เป็นการสแกนพอร์ตเพื่อค้นหาว่ามีพอร์ตหมายเลขใดเปิดอยู่ที่เครื่องปลายทางนั้นบ้าง

- TCP connect scan เป็นการคอนเน็กไปที่พอร์ตที่ต้องการบนเครื่องปลายทาง แล้วขอเปิดคอนเน็กชันของโปรโตคอล TCP ด้วยกลไกมาตรฐานที่เรียกว่า TCP three-way handshake

(SYN, SYN/ACK และ ACK) แต่วิธีนี้มักถูกตรวจจับได้โดยง่ายโดยไฟร์วอลล์ที่ไซต์ปลายทาง



รูปที่ 5-3 TCP 's 3-way handshake

รูปแสดงการเปิดคอนเนกชันของโพรโตคอล TCP จะอาศัยกลไก three way handshake โดยขั้นแรกจะส่งแพ็กเก็ต TCP ที่เซตค่า SYN เป็น 1 ให้ออกไปที่เครื่องปลายทาง ขั้นที่สอง เครื่องต้นทางจะได้รับ TCP SYN/ACK กลับมาและขั้นสุดท้าย จะส่งแพ็กเก็ต TCP ACK กลับไปอีกครั้งเพื่อยืนยันว่าได้รับแพ็กเก็ตในขั้นที่สองแล้ว

- TCP SYN scan เทคนิคนี้บางครั้งเรียกว่า half-open scanning สาเหตุเพราะว่า คอนเนกชันที่สมบูรณ์ของโพรโตคอล TCP ยังไม่ได้ถูกเปิดขึ้น เพราะเมื่อแพ็กเก็ต TCP ที่เซตค่าแฟล็ก SYN และ ACK ไว้เป็น 1 (TCP SYN/ACK) นั้นก็เพียงพอแล้วที่จะสรุปว่า พอร์ตดังกล่าวอยู่ในสถานะ LISTENING แต่ถ้าพอร์ตดังกล่าวไม่ได้เปิดอยู่ แพ็กเก็ต TCP ที่เซตค่าแฟล็ก RST และ ACK ไว้เป็น 1 (TCP RST/ACK) จะถูกส่งกลับมาแทน เทคนิคค่อนข้างน่าใช้กว่าเทคนิคแรกเพราะส่วนใหญ่แล้วไฟร์วอลล์ที่ไซต์ปลายทางมักตรวจจับได้ค่อนข้างยาก
- TCP FIN scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ที่เซตค่าแฟล็ก FIN เป็น 1 (TCP FIN) ไปยังพอร์ตที่ต้องการ ถ้าไดรเวอร์ของโพรโตคอล TCP/IP ที่เครื่องปลายทางได้ถูกพัฒนาขึ้นมาโดยมีฟีเจอร์ตามในมาตรฐาน RFC หมายเลข 793 ครบถ้วน (<http://www.ietf.org/rfc/rfc0793.txt>) เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกๆพอร์ตที่ปิดอยู่กลับมาให้ (กล่าวง่าย ๆ ก็คือ เราจะทราบหมายเลขพอร์ตที่ไม่ได้เปิดให้บริการ) โดยปกติแล้ว เทคนิคนี้มักใช้ได้กับเครื่องปลายทางที่รันยูนิกซ์
- TCP Xmas Tree scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ที่เซตค่าแฟล็ก FIN ,URG และ PUSH ไปยังพอร์ตเป้าหมายที่เครื่องปลายทาง และอาศัยมาตรฐาน RFC 793 อีกเช่นกัน เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกพอร์ตที่ปิดอยู่กลับมาให้

- TCP Null scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ออกไปโดยเซตค่าของทุกๆฟิลด์ให้เป็น 0 ทั้งหมด และ อาศัยมาตรฐาน RFC 793 อีกเช่นกัน เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกๆพอร์ตที่เปิดอยู่กลับมาให้
- TCP ACK scan เทคนิคนี้จะถูกใช้เพื่อค้นหา “rule” และ “policy” ต่างๆที่เซตไว้ที่ไฟร์วอลล์ เพื่อตรวจสอบดูว่าไฟร์วอลล์นั้นๆทำหน้าที่แค่เพียงกรองแพ็กเก็ตเกิดอย่างง่ายๆ หรือเป็นไฟร์วอลล์ที่มีความฉลาดพอสมควรและใช้เทคนิคการกรองแพ็กเก็ตขั้นสูง
- TCP Window scan เทคนิคนี้จะตรวจสอบพอร์ตที่เปิดอยู่ รวมทั้งตรวจสอบว่า พอร์ตใดบ้างที่ถูกฟิลเตอร์เอาไว้ไม่ให้ผ่านเข้าไปถึง และพอร์ตหมายเลขใดได้รับการอนุญาตไว้บ้าง โดยอาศัยช่องโหว่จากความผิดปกติบางอย่างในการแจ้งค่าของ TCP Window Size ของโปรโตคอล TCP/IP
- TCP RPC scan เทคนิคนี้ใช้งานได้เฉพาะกับเครื่องปลายทางที่รันยูนิกซ์เท่านั้น มันถูกใช้เพื่อตรวจสอบดูว่ามีเซอร์วิสใดทำงานอยู่บนเซอร์วิส RPC บ้าง รวมทั้งตรวจสอบเวอร์ชันของเซอร์วิสนั้นและโปรแกรมอื่นที่เกี่ยวข้อง
- UDP scan เทคนิคนี้จะส่งแพ็กเก็ตของโปรโตคอล UDP ไปยังพอร์ตเป้าหมาย ถ้าเครื่องปลายทางตอบกลับมาด้วยแพ็กเก็ต ICMP type PORT UNREACHABLE นั้นหมายความว่าพอร์ตนั้นเปิดอยู่ในทางตรงกันข้าม ถ้าเราไม่ได้รับแพ็กเก็ต ICMP type ดังกล่าว เราสามารถสรุปได้ว่าพอร์ตนั้นเปิดอยู่ เนื่องจากโปรโตคอล UDP เป็นโปรโตคอลลักษณะ connectionless คือไม่รับรองว่าแพ็กเก็ตที่ส่งไปจะถึงเครื่องปลายทางครบถ้วนหรือไม่ ดังนั้น ความถูกต้องของผลลัพธ์ที่ได้จากเทคนิคนี้ก็อาจขึ้นกับปัจจัยอื่นๆ ด้วยเช่น ปริมาณทราฟฟิกในเน็ตเวิร์กและทรัพยากรบนเครื่องปลายทาง นอกจากนั้นมันยังเป็นเทคนิคที่ค่อนข้างช้าอีกด้วยถ้าคุณกำลังสแกนเน็ตเวิร์กที่ใช้งานไฟร์วอลล์หรือเราเตอร์ที่มีการฟิลเตอร์กรองแพ็กเก็ต จึงขอให้เตรียมใจไว้ด้วยกับผลลัพธ์ที่ไม่คาดคิดของ UDP scan

ไค์เวอร์ของโปรโตคอล TCP/IP ของระบบปฏิบัติการบางตัวอาจส่งแพ็กเก็ต TCP RST กลับไปยังเครื่องต้นทางตลอดไม่ว่าพอร์ตๆ นั้นจะเปิดหรือปิดอยู่ ดังนั้นจึงเป็นไปได้ว่า ผลลัพธ์ที่ได้อาจแตกต่างกันไปไม่แน่นอน แต่อย่างไรก็ดี การตรวจสอบด้วยแพ็กเก็ต TCP SYN ธรรมดาๆนั้นจะทำงานได้ดีสำหรับทุกๆ โฮสต์

5.4 การตรวจหาประเภทของระบบปฏิบัติการ

จุดประสงค์ประการแรกของการสแกนคือ การค้นหา TCP port และ UDP port ที่เปิดอยู่บนเครื่องปลายทาง ส่วนจุดประสงค์ประการที่สองคือ การค้นหาประเภทของระบบปฏิบัติการที่รันอยู่บนเครื่องปลายทาง ประเภทของระบบปฏิบัติการที่เราทราบจะถูกนำไปใช้ประโยชน์ในขั้นตอนการค้นหารายละเอียดต่างๆ (enumeration) โดยอาศัยข้อบกพร่องต่างๆ ที่แต่ละระบบปฏิบัติการนั้นมี ดังนั้นเราจึงต้องมั่นใจว่า ระบบปฏิบัติการที่เราทราบนั้นเป็นข้อมูลที่ต้องการ

ส่วนใหญ่เซิร์ฟเวอร์ที่ให้บริการมาตรฐานบนอินเทอร์เน็ตเช่น เว็บเซิร์ฟเวอร์, เมล์เซิร์ฟเวอร์, FTP Server นั้น แอปพลิเคชันที่ให้บริการจะสามารถบอกเราได้ในระดับหนึ่งว่าใช้ระบบปฏิบัติการอะไร เช่น IIS จะต้องทำงานอยู่บน Window NT หรือ Window2000 , Apache จะต้องรันอยู่บน Unix หรือ Linux ซึ่งหากแอสกเกอร์สามารถได้ข้อมูลเหล่านี้มาก็จะสามารถทราบได้เองว่าเป้าหมายใช้ระบบปฏิบัติการอะไรอยู่โดยไม่ต้องแสกนให้ยุ่งยาก แต่ก็มีความยากเช่นกันที่ไม่สามารถสืบค้นระบบปฏิบัติการของเป้าหมายได้ว่าเป็นระบบปฏิบัติการอะไร โดยอาศัยการตรวจสอบเฉพาะแอปพลิเคชันเพียงอย่างเดียว ดังตัวอย่างต่อไปนี้

5.4.1 มีแอปพลิเคชันมาตรฐานทำงานอยู่ แต่แอปพลิเคชันได้ถูกปรับแต่งมาอย่างดี ไม่ให้บอกรายละเอียดของตนเองแก่ผู้อื่น คือมีหน้าที่ให้บริการอย่างเดียว โดยทั่วไปแล้ว แอปพลิเคชันเซิร์ฟเวอร์ที่ทำงานอยู่ เมื่อมีไคลเอนต์ติดต่อขอรับบริการเข้ามา เซิร์ฟเวอร์ก็จะส่งข้อความให้ทราบว่าตนเองชื่ออะไร เวอร์ชันไหน ให้ไคลเอนต์ทราบเสียก่อน(จะตรวจสอบได้ง่ายด้วยการ Telnet ไปที่พอร์ตของแอปพลิเคชันดังกล่าว) ข้อมูลเหล่านั้นเรียกว่าแบนเนอร์(banner) ซึ่งเปรียบเสมือนป้ายประกาศที่จะประชาสัมพันธ์ให้ผู้ใช้งานทราบทุกครั้งว่าขณะนี้กำลังใช้งานเซิร์ฟเวอร์ของผู้ผลิตรายไหนอยู่ เพื่อผู้ใช้ที่ฟังไคลเอนต์ประทับใจจะได้นำไปบอกต่อได้ และผู้ผลิตซอฟต์แวร์เหล่านี้ทุกรายก็จะมีแบนเนอร์ดิมมากับซอฟต์แวร์เหล่านี้เสมอแต่สำหรับแอปพลิเคชันที่ถูกปรับแต่งมาอย่างดีนั้นจะไม่แสดงตัวและให้ข้อมูลเหล่านี้ออกมา เช่น มีเซิร์ฟเวอร์ที่ทำงานอยู่สามารถให้บริการแก่บราวเซอร์ได้ตามปกติ แต่บราวเซอร์อาจไม่ได้รับข้อมูลใดๆจากเซิร์ฟเวอร์เลยว่าเป็นแอปพลิเคชันของใคร ยี่ห้ออะไร เวอร์ชันอะไร รู้เพียงแต่ว่าเป็นเซิร์ฟเวอร์ที่อาจเป็นได้ทั้ง Apache, IIS, Netscape หรือ เว็บเซิร์ฟเวอร์อื่นใดก็ได้ เมื่อไม่รู้ว่าแอปพลิเคชันมีรายละเอียดอย่างไรก็ยอมทำให้ไม่สามารถรู้ถึงระบบปฏิบัติการด้วยเช่นกัน

5.4.2 ไม่มีแอปพลิเคชันมาตรฐานทั่วไปรันอยู่ หรือไม่มีการให้บริการใดๆ กรณีนี้เป้าหมายอาจเป็นเซิร์ฟเวอร์ธรรมดาที่ใช้งานเฉพาะอย่างและไม่ได้ให้บริการมาตรฐานทั่วๆไปบนอินเทอร์เน็ตเมื่อไม่มีการให้บริการก็ย่อมไม่มีช่องทางในการสอบถามข้อมูลจากการบริการเหล่านั้นได้ เซิร์ฟเวอร์ดังกล่าวย่อมเป็นเหมือนกล่องดำบนเน็ตเวิร์กที่ไม่มีใครทราบว่าเซิร์ฟเวอร์อะไร, ระบบปฏิบัติการอะไร, ให้บริการอะไร เซิร์ฟเวอร์ประเภทนี้อาจเป็นที่สะดุดตาของแอสกเกอร์ทั้งหลายได้ เพราะดูเหมือนมีความลับอยู่ภายใต้การป้องกันที่แข็งแรง

เมื่อไม่สามารถหาข้อมูลของเป้าหมายด้วยวิธีทั่วไปได้เนื่องจากติดขัดด้วยข้อจำกัดทั้ง 2 ประการข้างต้นนั้น จึงต้องใช้วิธีแสกนเพื่อให้ได้มาซึ่งข้อมูลเหล่านี้ การแสกนเซิร์ฟเวอร์เพื่อตรวจสอบว่าเป็นระบบปฏิบัติการอะไร เวอร์ชันไหนเป็นการใช้ข้อบกพร่องของโปรโตคอลที่มีได้มีการกำหนดชัดเจนครอบคลุมทุกเงื่อนไขของการสื่อสารข้อมูล ดังนั้นเมื่อเหตุการณ์ดังกล่าวเกิดขึ้น จึงไม่มีมาตรฐานที่ทุกคนต้องยึดร่วมกัน การตอบสนองของระบบปฏิบัติการแต่ละชนิดจึงแตกต่างกันออกไปขึ้นอยู่กับผู้ผลิตระบบปฏิบัตินั้นจะอิมพลิเมนต์ TCP/IP อย่างไร และแน่นอนว่าระบบปฏิบัติการแต่ละรุ่นก็มีลักษณะ

การตอบสนองแตกต่างกันออกไป การแสดงด้วยเทคนิคนี้ส่วนใหญ่จะกระทำบนโปรโตคอล TCP เนื่องจากมีส่วนที่ไม่ได้กำหนดไว้ในโปรโตคอลอยู่ค่อนข้างมาก นั่นคือ TCP Flag เพราะ TCP Flag เป็นส่วนสำคัญที่ใช้ในการควบคุมการสื่อสารของ TCP แต่ Flag เหล่านั้นก็ไม่ได้ถูกนำไปใช้งานทุกๆเงื่อนไข จึงมี Flag บางเงื่อนไขซึ่งไม่มีโอกาสเกิดขึ้นได้จริงในการทำงานปกติ และ Flag ที่ไม่ใช่ Flag ปกติ และไม่ได้มีกำหนดไว้ในโปรโตคอลโดยเฉพาะโดยการสลับ Flag ของ TCP ให้เป็นค่าต่างๆ ที่ไม่มีการใช้งาน หลักการสำคัญก็คือระบบปฏิบัติการแต่ละชนิดแต่ละเวอร์ชันก็จะตอบสนองแพ็กเก็ตลักษณะนี้แตกต่างกันออกไป และเมื่อรวบรวมผลลัพธ์ที่ตอบจากระบบปฏิบัติการแต่ละชนิดแล้วจะพบว่าข้อมูลเหล่านี้สามารถบอกถึงระบบปฏิบัติการได้เป็นอย่างดี

Impossible TCP Flags กับ OS Fingerprint

ก่อนที่จะดูถึงรายละเอียดการแสดกจากโปรแกรมที่ใช้เทคนิคของ Flag นี้ขอให้ศึกษาถึงลักษณะของ Flag ปกติ และ Flag ที่ไม่ปกติของ TCP เสียก่อน การที่เราแบ่งแยก Flag ของ TCP ได้เป็น 2 ชนิดเนื่องจากในโปรโตคอลจะใช้ Flag เป็นสัญลักษณ์ที่บอกถึงลักษณะและจังหวะของข้อมูล TCP เชกเมนต์นั้นๆจะมี Flag ในลักษณะใดลักษณะหนึ่งตามที่กำหนดอยู่ในโปรโตคอลซึ่งทำให้ผู้ได้รับข้อมูลนั้นๆจะมี Flag ในลักษณะใดลักษณะหนึ่งตามที่กำหนดอยู่ในโปรโตคอลซึ่งทำให้ผู้ได้รับข้อมูลนั้นๆสามารถตอบสนองเป็นมาตรฐานเดียวกัน Flag ประเภทนี้จะเป็น Flag ปกติแต่ Flag บางประเภทร้านหากการสื่อสารยึดถือตามโปรโตคอลอย่างถูกต้องแล้ว จะไม่มีโอกาสเกิดขึ้นได้เลย เช่น SYN, Fin คือในแพ็กเก็ตเดียวกันมีทั้ง 2 อย่างซึ่งจะไม่มีโอกาสเกิดขึ้นได้อย่างเด็ดขาด ไม่ว่าในกรณีใดๆของ TCP แต่เนื่องจากแฮกเกอร์ได้ทำการส่งข้อมูลมายังเลเยอร์ล่างโดยตรงไม่ผ่านเลเยอร์ของ TCP ซึ่งด้วยวิธีการนี้ไม่ว่า Flag ใดๆ ก็ส่งออกมาได้เสมอ

Flags	Open port	Closed port
None	0	RA
F	0	RA
S	SA	RA
SF	SFA	RA
R	0	0
RF	0	0
SR	0	0
SRF	0	0
A	R	R
FA	R	R
SA	R	R
SFA	R	R

RA	0	0
RFA	0	0
SRA	0	0
SFRA	0	0

ตารางที่ 5-1 TCP Flags Combination

จากตาราง 5-1 แสดงทุกค่าที่เป็นไปได้ในการรวมกัน (Combination) ของ TCP Flag พร้อมด้วยการตอบรับต่อ Flag เหล่านั้นทั้งจากพอร์ตที่เปิดและพอร์ตที่ปิดซึ่งในการสื่อสารของ TCP จริงๆ นั้นจะไม่ได้ใช้งาน Flag ครบทุกกรณี ส่วนที่เหลือนั้นคือ Flag ที่ไม่มีโอกาสเกิดขึ้นในการสื่อสารจริง หรือเป็นไปได้ไม่ได้ หากเป็นการสื่อสารผ่านโปรโตคอลแล้ว โปรโตคอลจะไม่อนุญาตให้ Flag เหล่านี้เกิดขึ้นได้โดยเด็ดขาด และแน่นอนว่าผู้ที่ทำการสื่อสารข้อมูลตามปกติในฐานะผู้ใช้ซึ่งต้องสื่อสารข้อมูลผ่านเลเยอร์ต่างๆของโปรโตคอล ก็ไม่มีทางจะสร้างแพ็กเก็ตที่ออกนอกกลุ่มนอกทางจากโปรโตคอลที่กำหนดได้ แต่นั่นมิได้หมายความว่าแพ็กเก็ตเหล่านั้นไม่มีโอกาสเกิดขึ้นได้โดยสิ้นเชิง ในเมื่อผู้ใช้นั้นคือแฮกเกอร์ซึ่งเป็นผู้ควบคุมโฮสต์ของตัวเองโดยสมบูรณ์ก็ย่อมสามารถจะส่งข้อมูลไปยังโปรโตคอลในระดับดาต้าลิงก์เลเยอร์ คือโปรแกรมควบคุมฮาร์ดแวร์ระดับล่างซึ่งอยู่ต่ำกว่า TCP/IP ให้ส่งข้อมูลใดๆก็ได้โดยไม่ต้องติดขัดกับขีดจำกัด และเงื่อนไขต่างๆที่โปรโตคอลระดับบนกำหนดขึ้น เพียงเท่านี้โปรโตคอลระดับบนไม่ว่า IP, ICMP, UDP และ TCP จะกำหนดข้อห้ามไว้อย่างไรก็ไม่มีความหมาย

จากตารางข้างต้นจะเห็นได้ว่าการผสมกันของ Flag ที่เป็นไปไม่ได้ (Impossible Flags) อยู่หลายประเภท และแพ็กเก็ตเหล่านี้ที่โปรโตคอลไม่ได้บัญญัติไว้ว่าโฮสต์ที่ได้นั้นจะต้องตอบสนองอย่างไร (อาจจะคิดอย่างไรเสียแพ็กเก็ตเหล่านี้ก็ไม่มีโอกาสเกิดขึ้นได้อยู่แล้ว จึงไม่มีการกำหนดการตอบรับไว้ในโปรโตคอลอย่างชัดเจน) เมื่อมีการส่งแพ็กเก็ตเหล่านี้ไปยังโฮสต์ซึ่งมีระบบปฏิบัติการรับผิดชอบการสื่อสารข้อมูล แน่นอนว่าทุกระบบปฏิบัติการต้องมีการตอบสนองอย่างใดอย่างหนึ่ง เพียงแต่ไม่มีมาตรฐานให้ยึดถือว่าจะตอบอย่างไร (การไม่ส่งแพ็กเก็ตใดๆ ถือเป็นการตอบสนองอย่างหนึ่งโดยการไม่ตอบ) และไม่ว่าจะตอบรับอย่างไรก็ล้วนแต่ไม่มีผลต่อการทำงานในสถานะปกติทั้งสิ้น การตอบในส่วนนี้เป็นส่วนที่ทุกคนมองข้ามไปและนอกเหนือความคาดหมาย อาจมีระบบปฏิบัติการบางค่ายที่ให้ความสนใจเรื่องนี้ก็ให้ตอบด้วยแพ็กเก็ตต่างๆอย่างจงใจ แต่อาจมีบางระบบปฏิบัติการบางระบบที่การตอบสนองต่อแพ็กเก็ตเหล่านี้เป็นไปตามยถากรรม คือมิได้มีการกำหนดเงื่อนไขของแพ็กเก็ตเหล่านี้ไว้ แต่การตอบสนองที่เกิดขึ้นเป็นเพราะแพ็กเก็ตเหล่านั้นไม่เข้าเงื่อนไขใดๆเลย ผลที่ออกมาจากการถูกกระตุ้นโดยอิมพอสสิเบิลบางครั้งแม้แต่ผู้ผลิกระบบปฏิบัติการเองก็ยังไม่เคยทดสอบ และไม่ทราบด้วยซ้ำว่าระบบปฏิบัติการของตัวเองจะตอบอย่างไร

การตอบสนองที่เกิดขึ้นของอิมพอสสิเบิลแพ็กเก็ตเหล่านี้ไม่ว่าผู้ผลิตจะตั้งใจให้เป็นเช่นนั้นหรือไม่ก็ตาม แต่การตอบสนองทุกครั้งก็จะเป็นเช่นนั้นอยู่เสมอ (เนื่องจากระบบปฏิบัติการก็เป็นโปรแกรมคอมพิวเตอร์ประเภทหนึ่งที่ทำงานตามเงื่อนไขของโปรแกรมที่ถูกกำหนดไว้ หากเงื่อนไขแบบหนึ่งโปรแกรมก็ตอบสนองแบบหนึ่ง และเงื่อนไขที่กำลังสนใจนี้คือแพ็กเก็ต หากแพ็กเก็ตเปลี่ยนไปการตอบสนอง

ก็จะเปลี่ยนไปอีกแบบหนึ่ง และเมื่อไรก็ตามที่เงื่อนไขเหมือนเดิม การตอบสนองของโปรแกรมก็จะยังคงเหมือนเดิม) คือไม่ว่าแฟลคที่ส่งเข้าไปจะแปลกประหลาดอย่างไร เมื่อไรการตอบสนองทุกครั้งก็จะออกมาเหมือนเดิม ยกตัวอย่างเช่นระบบปฏิบัติการ SunOS 4.13 เมื่อได้รับ TCP แพ็กเก็ตที่มีแฟลคเป็น SFRA มาที่พอร์ตที่ปิดอยู่ระบบปฏิบัติการก็จะไม่ตอบอะไรกลับไปเลย และหากได้รับมาที่พอร์ตที่เปิดอยู่ก็จะไม่ตอบสนองอะไรกลับไปเลยเช่นกัน ดังนั้นที่มีการส่งแพ็กเก็ตที่มีแฟลค SFRA ไปยัง SunOS 4.13 ก็ จะได้รับการตอบสนองเช่นนี้อยู่เสมอ

สำหรับการตอบกลับมาของอิมพอสสิเบิลแฟลคเพียงแฟลคเดียวเป็นการยากที่จะชี้ชัดว่ามาจาก ระบบปฏิบัติการอะไร Linux Redhat 7.0 อาจจะตอบสนองต่อ SFRA แฟลคเช่นเดียวกับ SunOS 4.13 ก็ เป็นได้ ดังนั้นเพื่อให้ชี้ชัดได้ถึงระบบปฏิบัติการได้อย่างแม่นยำที่สุดจึงต้องทดสอบโดยอิมพอสสิเบิล แฟลคหลายชนิด และดูผลการตอบรับทั้งหมด จึงมั่นใจได้ว่าไม่ว่าระบบปฏิบัติการชนิดใดเมื่อได้รับชุด ของอิมพอสสิเบิลแฟลคเหล่านี้จะมีผลการตอบรับที่แตกต่างออกไปไม่ซ้ำกัน และหากนำผลลัพธ์ที่ได้ไป เปรียบเทียบแล้วสามารถระบุได้ทันทีว่าเป็นการตอบสนองจากระบบปฏิบัติการใด

แพทเทิร์นการตอบกลับมาจากการกระตุ้นหลายๆแบบของอิมพอสสิเบิลแฟลคที่เป็นเอกลักษณ์ ของระบบปฏิบัติการแต่ละชนิดที่เป็นเสมือน ลายนิ้วมือของระบบปฏิบัติการ (OS Fingerprint) ไว้อ้างอิงว่า ระบบปฏิบัติการอะไร เวอร์ชันใด ซับเวอร์ชันใด มีลายนิ้วมือเป็นอย่างไร

โปรแกรมที่ใช้สำหรับการทดสอบและแสกนหาระบบปฏิบัติการนี้ใช้หลักการที่เรียบง่ายโดย อาศัยฐานข้อมูลลายนิ้วมือที่เก็บจากระบบปฏิบัติการต่างๆที่มีอยู่บนโลกมาใช้เป็นฐานในการอ้างอิง หลังจากนั้นก็ทำการส่งชุดของแพ็กเก็ตที่มีอิมพอสสิเบิลไปทดสอบยังโฮสต์เป้าหมายแล้วนำผลการตอบ รับมาเปรียบเทียบกับลายนิ้วมือที่มีอยู่ในฐานข้อมูล หากตรงกับระบบปฏิบัติการอะไรก็ให้สันนิษฐานได้ว่า ระบบปฏิบัติการที่ทำงานที่โฮสต์เป้าหมายนั้นเป็นระบบปฏิบัติการตามที่ระบุในฐานข้อมูลนั่นเอง ความ แม่นยำของการทดสอบหาระบบปฏิบัติการด้วยวิธีนี้จะขึ้นอยู่กับจำนวนของแพ็กเก็ตที่ใช้ทดสอบ ยังมีการ ทดสอบหลายแพ็กเก็ตผลการตอบรับจะยิ่งชี้ไปยังระบบปฏิบัติการรุ่นใดรุ่นหนึ่งได้อย่างแม่นยำมากขึ้น ส่วนอีกปัจจัยหนึ่งคือความทันสมัยของการปรับปรุงฐานข้อมูลลายนิ้วมือให้ทันต่อระบบปฏิบัติการเวอร์ ชัน ใหม่ๆอยู่เสมอ

5.4.1 Active Stack Fingerprinting

Stack fingerprinting เป็นเทคโนโลยีที่ช่วยทำให้มั่นใจได้ว่าประเภทของระบบปฏิบัติการที่ค้นหา ได้นั้นเป็นระบบปฏิบัติการที่ถูกต้อง มีเปอร์เซ็นต์ความน่าเชื่อถือสูง โดยอาศัยหลักการที่ว่า ผู้ผลิต ระบบปฏิบัติการแต่ละรายมักพัฒนาไดรเวอร์ของโพรโตคอล TCP/IP และเซอร์วิสที่ทำงานบน โพรโตคอล TCP/IP ให้มีเอกลักษณ์เฉพาะตัวเป็นของตัวเอง ซึ่งมักแตกต่างกับของระบบปฏิบัติการอื่น

ดังนั้น โดยการตรวจวัดความแตกต่างเหล่านี้ เราจะสามารถเริ่มคาดเดาได้อย่างมีเหตุผล แต่ เพื่อให้ความน่าเชื่อถือสูงสุด Stack fingerprinting จำเป็นต้องอาศัยการคอนเน็กไปพอร์ตที่เปิดอยู่อย่าง น้อยหนึ่งพอร์ต แต่ การทำงานของโครงการนี้ สามารถคาดเดาได้อย่างมีเหตุผล ถึงแม้ว่าจะไม่ได้คอนเน็ก ไปที่พอร์ตใดเลย แต่ผลที่ได้ก็อาจยังไม่น่าเชื่อถือนัก โดยให้สำรวจวิธีการตรวจวัดความแตกต่างกันที่ละ วิธี

- Fin probe ใช้การส่งแพ็กเก็ตของโพรโตคอล TCP โดยเซตแฟล็ก Fin ให้เป็น 1 ไว้ ตามมาตรฐาน RFC 793 ระบุไว้ว่า พฤติกรรมที่ถูกต้องจะต้องไม่มีการส่งแพ็กเก็ตอะไรตอบสนองกลับไป แต่ทว่า ใครเวอร์ของโพรโตคอล TCP/IP ในระบบปฏิบัติการบางตัว อย่างเช่น วินโดวส์เอ็นที จะตอบสนองกลับมาด้วยแพ็กเก็ตของโพรโตคอล TCP ที่เซตแฟล็ก Fin และ ACK ให้เป็น 1 ซึ่งเครื่องมือส่วนมากได้นำเทคนิคนี้ไปใช้กัน
- Bogus Flag probe ใช้การส่งแพ็กเก็ตของโพรโตคอล TCP โดยเซตแฟล็ก SYN ให้เป็น 1 พร้อมทั้งเซตบิตตำแหน่งที่ยังไม่ได้ใช้งานให้เป็น 1 ด้วย บางระบบปฏิบัติการเช่น ลินุกซ์ จะตอบสนองกลับมาด้วยการเซตแฟล็กบางตัวในแพ็กเก็ต ว่ามักเป็นค่าอะไร อย่างไรก็ตามบางระบบปฏิบัติการจะทำการ reset connection เมื่อได้รับแพ็กเก็ตนี้
- TCP Initial Sequence Number (ISN) sampling ใช้วิธีการตรวจหาแพทเทิร์นของ Sequence number ที่อยู่ในส่วนหัวของแพ็กเก็ตที่ได้รับการตอบสนองต่อการร้องขอการเชื่อมต่อ ว่าเป็นค่าอะไร ซึ่งสามารถแบ่งได้หลายกลุ่มเช่น ถ้าเป็นแบบ traditional 64K จะพบใน UNIX รุ่นเก่า, แบบ Random increments จะพบใน Solaris, IRIX, FreeBSD, Digital UNIX, Cray ในเวอร์ชันใหม่, แบบ True "random" จะพบใน Linux 2.0.*, OpenVMS, AIX เวอร์ชันใหม่, ส่วน Windows จะเป็นแบบ "time dependent" model คือค่าของ ISN จะเพิ่มขึ้นจำนวนหนึ่งที่กำหนดไว้ในแต่ละช่วงเวลา, และในบางครั้งจะใช้ค่า ISN ค่าเดียวไม่เปลี่ยนแปลง เช่นใน 3Com hubs จะใช้เป็น 0x803 ตลอดและใน Apple LaserWriter printers จะใช้เป็น 0xC7001
- "Don't fragment bit" monitoring บางระบบปฏิบัติการได้เซตบิต "Don't fragment bit" ไว้เพื่อเพิ่มความเร็วในการส่งข้อมูล ให้มอนิเตอร์บิตนี้เพื่อตรวจดูว่าระบบปฏิบัติการไหนเซตบิตนี้บ้าง
- TCP initial window size ใช้วิธีดูขนาดของ TCP window เพราะบางระบบปฏิบัติการจะมีการลือค่าไว้เลยว่าขนาดของ TCP window เป็นเท่าไร (เช่น AIX เป็นเพียงระบบปฏิบัติการเดียวที่มีขนาดของ window เท่ากับ 0x3F25 ส่วน window NT มีขนาด 0x402E) ค่านี้มักเป็นค่าเฉพาะตัวของแต่ละระบบปฏิบัติการด้วย จึงยังทำให้ผลที่ได้มีความถูกต้องมากขึ้น
- ACK value ระบบปฏิบัติการแต่ละระบบมักเซตค่าในฟิลด์ ACK ไม่เหมือนกัน บางระบบเซตค่าฟิลด์ ACK ให้สอดคล้องตามค่าของฟิลด์ SYN ที่เซตไว้ในฝั่งผู้ส่ง บางระบบจะเซตค่าฟิลด์ ACK ให้บวกจากค่าของฟิลด์ SYN ไปอีกหนึ่ง
- ICMP error message quenching บางระบบปฏิบัติการอาจปฏิบัติตามมาตรฐาน RFC 1812 และมีการจำกัดอัตราการส่งข้อความแจ้งข้อผิดพลาด ดังนั้น (ใน Linux kernel จะจำกัดการส่งข้อความแจ้งข้อผิดพลาดไปยังปลายทางที่อัตรา 80 แพ็กเก็ตต่อ 4±0.25 วินาที) โดยการส่งแพ็กเก็ตของโพรโตคอล UDP ไปยังหมายเลขพอร์ตสูงๆ แล้วค่อยนับจำนวนของ ICMP type PORT UNREACHABLE Message ที่ตอบกลับมาภายในช่วงเวลาที่กำหนด
- ICMP message quoting เมื่อพบข้อผิดพลาดเกี่ยวกับโพรโตคอล TCP/IP ระบบปฏิบัติการแต่ละประเภทจะให้ข้อมูลและสาเหตุต่างๆมาในแพ็กเก็ตของ ICMP ไม่เท่ากัน บางระบบจะให้รายละเอียดมากบางระบบจะให้รายละเอียดน้อย (ใน Solaris จะส่งกลับมา a bit more และใน

Linux จะส่งกลับมากว่า even more than that) ดังนั้นโดยการสำรวจข้อมูลที่ได้มานี้ เราพอจะใช้ในการคาดเดาประเภทของระบบปฏิบัติการได้

- ICMP error message-echoing integrity บางระบบปฏิบัติการอาจคัดแปลงส่วนหัวของแพ็กเก็ต IP เมื่อมีการส่ง ICMP error message ด้วยการตรวจสอบลักษณะของการคัดแปลงดังกล่าวนี้คุณสามารถนำมาใช้ในการคาดเดาได้
- Type of service (TOS) ให้คุณสำรวจฟิลด์ที่ชื่อ Type of service ที่อยู่ในแพ็กเก็ต ICMP ประเภท port unreachable ซึ่งโดยปกติหลายระบบปฏิบัติการจะใช้ค่าศูนย์ แต่บางระบบอาจใช้ค่าอื่นเช่น Linux ใช้ 0xC0
- Fragmentation handling แต่ละระบบปฏิบัติการจะจัดการกับแพ็กเก็ตที่ถูกแฟรกเมนต์หรือหั่นซอยไม่เหมือนกัน เมื่อมีการประกอบแพ็กเก็ตย่อยขึ้นมาเป็นแพ็กเก็ตที่สมบูรณ์ บางระบบจะเจียนทับ
แพ็กเก็ตย่อยอันเก่าด้วยแพ็กเก็ตย่อยอันใหม่หรือบางระบบก็ทำในทางตรงกันข้าม โดยการสังเกตพฤติกรรมตรงนี้ เราพอจะใช้ในการคาดเดาประเภทของระบบปฏิบัติการได้เช่นเดียวกัน สามารถหาข้อมูลเพิ่มเติมได้ที่ www.secnets.com
- TCP options ได้ถูกกำหนดไว้ในมาตรฐาน RFC 793 และได้รับการปรับปรุงในมาตรฐาน RFC 1323 ในปัจจุบัน ผู้ผลิตหลายรายได้มีการอิมพลีเมนต์ออปชันพิเศษที่อยู่ใน RFC 1323 ไว้ในระบบปฏิบัติการของตน ดังนั้น ด้วยการส่งแพ็กเก็ตที่เซตออปชันหลายๆออปชันไปทดสอบ อย่างเช่น no operation, maximum segment size, window scale factor และ timestampsมันเป็นไปได้ที่เราจะตั้งสมมติฐานเกี่ยวกับระบบปฏิบัติการที่รันที่เครื่องเป้าหมาย

ยกตัวอย่าง

Window Scale=10; NOP; Max Segment Size = 265; Timestamp; End of Ops;

บางระบบปฏิบัติการ เช่น FreeBSD จะ support ทุกออปชันข้างต้นขณะที่ Linux 2.0.X จะ support บางออปชัน Linux 2.1.x support ทุกออปชัน

แม้ว่าหลายระบบปฏิบัติการจะ support ออปชันเดียวกันแต่บางทีเราก็สามารถแยกแยะได้โดยจากออปชัน the_values_of เช่น ถ้าส่งค่า MSS เล็กๆไปที่ Linux โดยทั่วไปแล้วมันจะส่ง MSS echo กลับไป ส่วนระบบปฏิบัติการอื่นจะส่งค่าที่แตกต่างกันกลับไป แต่ถ้ายังได้ผลลัพธ์เหมือนกันอีกก็สังเกตลำดับของออปชันที่ได้รับมา เช่น Solaris จะเป็น 'NNTNWME' ซึ่งหมายความว่า <no op><no op><timestamp><no op><window scale><echoed MSS> ขณะที่ Linux 2.1.122 จะเป็น MENNTNW ซึ่งจะเห็นได้ว่าเป็นออปชันเดียวกัน ส่ง MSS echo เหมือนกัน แต่ลำดับที่ส่งมาไม่เหมือนกัน

- SYN Flood Resistance บางระบบปฏิบัติการจะไม่ยอมรับการ connection ครั้งใหม่ ถ้ามีการส่งแพ็กเก็ต SYN ไปมากเกินไป ซึ่งหลายระบบปฏิบัตินั้นสามารถที่จะจัดการกับแพ็กเก็ตที่ส่งเข้ามาได้ไม่เกินครั้งละ 8 แพ็กเก็ต แต่ใน kernel ของ Linux รุ่นใหม่มีวิธีการป้องกันปัญหานี้เช่น

การใช้ SYN cookies ดังนั้นเราก็สามารถรู้ได้ว่าเป็นระบบปฏิบัติการอะไรโดยการส่งแพ็กเก็ตไป 8 แพ็กเก็ตไปยังพอร์ตที่เปิดอยู่แล้วดูว่าสามารถ connect ไปยังพอร์ตนั้นได้หรือไม่

5.5 นัลเซสชัน(Null session)

เนื่องจากระบบปฏิบัติการ วินโดวส์ 2000 และ เอ็นที มีจุดอ่อนอยู่คือการฟังพาโปรโตคอล CIFS/SMB และโปรโตคอล NetBIOS ทั้งนี้เนื่องจาก CIFS/SMB และ NetBIOS นั้นเปิดโอกาสให้มีการสอบถามข้อมูลต่างๆของระบบผ่านทาง TCP port หมายเลข 139 ได้โดยที่ไม่จำเป็นต้องล็อกออนเข้าสู่ระบบเลย ขั้นตอนแรกในประโยชน์จากจุดอ่อนนี้ก็คือ ให้สร้างคอนเนกชันไปยัง NT/2000 โดยไม่ต้องล็อกออนด้วยการเปิดคอนเนกชันด้วยแบบที่เรียกว่า “null session” ดังนั้นสมมุติว่า เราทราบผลลัพธ์ของการสแกนพอร์ตว่า TCP port 139 ได้เปิดอยู่ให้ทำขั้นตอนต่อไปนี้

net use \\161.246.5.45\IPC\$ “”/u:””

คำสั่งข้างต้นนี้เป็นการคอนเนกไปที่แชร์พิเศษที่เปิดไว้สำหรับการสื่อสารระหว่างโปรเซส (Interprocess Communication : IPC) บนเครื่องที่มีหมายเลข แอดเดรส 161.246.5.45 โดยใช้แอดเดสที่ Anonymous User พร้อมด้วยรหัสผ่านเป็น null (“”) ซึ่งถ้าสำเร็จ ก็เท่ากับว่าได้เปิดแซนแนลไว้เพื่อเตรียมดึงข้อมูลต่างๆ โดยข้อมูลที่เป็นไปได้ก็อย่างเช่น ข้อมูลเกี่ยวกับเน็ตเวิร์ก ชื่อแชร์ โฟลเดอร์ ชื่อแอดเดสของผู้ใช้และค่าต่างๆ ในรีจิสตรีของวินโดวส์ เป็นต้น

5.6 ตัวอย่างเครื่องมือที่ใช้ในการสำรวจระบบเครือข่าย

เราได้ทำการคัดเลือกโปรแกรมที่มีผู้ใช้ นิยมใช้ในปัจจุบันมาเปรียบเทียบกันในเรื่องฟังก์ชันการทำงาน ประสิทธิภาพการทำงานดังนี้

5.6.1. Tivoli NetView 6.0

แหล่งที่มา <http://www-3.ibm.com/software/tivoli/products/netview/>

ระบบปฏิบัติการที่สนับสนุน

AIX , Linux , Solaris , Windows NT , Windows 2000

5.6.2. 3Com(R) Network Supervisor 3.0

แหล่งที่มา <http://www.3com.com/3ns/>

ระบบปฏิบัติการที่สนับสนุน

Windows95 , Windows98 , WindowsNT4 , Windows2000 , WindowsXP

5.6.3. GFI LANguard Scanner 3.2

แหล่งที่มา <http://www.gfi.com/lannetscan/>

ระบบปฏิบัติการที่สนับสนุน

Windows2000/XP

5.6.4. Alchemy Eye 4.9.7

แหล่งที่มา <http://www.alchemy-lab.com/products/eye/>

ระบบปฏิบัติการที่สนับสนุน

Windows NT/2000/XP

5.6.5. WhatUp Gold 8.0

แหล่งที่มา <http://www.ipswitch.com/Products/network-management.html>

ระบบปฏิบัติการที่สนับสนุน

Windows 98/ME/NT/2000/XP/Server 2003

5.6.6. OptiView Console Viewer 6.0

แหล่งที่มา

<http://www.flukenetworks.com/us/LAN/Monitoring+Analysis+Diagramming/OptiView+Console/Overview.htm>

ระบบปฏิบัติการที่สนับสนุน Windows NT/2000/XP